

# Firmware 7.15 · Block 4 audit report

Bitcoin signing history, change paths and shared transport · 22 September 2026

**Local audit judgment:** no new in-scope product defect identified in the pinned current candidate. The selected regressions executed in full and Bitcoin-only native images. Copilot review is a separate final checkpoint and is not yet claimed by this report.

## Identity and canonical method

Base: audit/715-sop-review-budget @ 7d2c76bce1b49449cc80051cd431b7b1a487a1f3. Report-generation predecessor: c0cf58f741b027c91ce3e045943d3b0905b3adc1. The containing final PR head is recorded in the PR body after commit. Candidate source: audit/715-scope-repair @ 614425a2a14d0113de251e7944118e47f31f5265. Canonical product release/7.15 @ af979cd5099349ba58ec10d1b7eedeb67662c602 remains separate.

Main-worktree master template SHA256:

8c6ef0cdb27bc028befec2c4614f3bb9b672010e84fd797c829dea83b1c88315. Historical counts use `git show --format= --numstat --no-renames COMMIT_SHA`; PR counts use `git diff --numstat 7d2c76bce1b49449cc80051cd431b7b1a487a1f3..c0cf58f741b027c91ce3e045943d3b0905b3adc1`. The named immutable range includes the report files only after they are committed. The final PR diff must match these paths and counts; its containing SHA cannot appear inside its own report. Counts include tests and may count edited lines in multiple historical commits. They are not a net product diff.

## Review PR file inventory

| File                                                 | Added | Deleted | Meaning                              |
|------------------------------------------------------|-------|---------|--------------------------------------|
| docs/release/audit-units/P04-block-scope-20260922.md | +116  | -0      | Audit artifact; no firmware behavior |

## Exact candidate dependency pins

| Submodule                      | Commit                                   |
|--------------------------------|------------------------------------------|
| code-signing-keys              | a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec |
| deps/crypto/trezor-firmware    | 8a392f70a5d5575ece3dfb35f115d4a4b27f497c |
| deps/device-protocol           | 27d3fa1f6215139cde6411f9a2882f36bb373fc9 |
| deps/googletest                | 7888184f28509dba839e3683409443e0b5bb8948 |
| deps/python-keepkey            | b76ee610dd18934ee3aeeb36cfc541e8799eb46d |
| deps/qrenc/QR-Code-generator   | 6dfbfdad5d9303ed190d1c3cb7bec34b565b6ce8 |
| deps/sca-hardening/SecAESSTM32 | 71d356a1141624994cf613bd2d2583892e8e6d5a |

## Original P04 units

| Commit                                   | Change                            | Files | Added | Deleted |
|------------------------------------------|-----------------------------------|-------|-------|---------|
| 29e14b4a417875495bb5d029e844294f05125c9  | Input history across outputs      | 6     | +56   | -35     |
| b57eb71c2ee1babfeb20805b7f6b64ad70c4e925 | Accepted history after refusal    | 2     | +19   | -2      |
| a1e7f53155ee3db53991f9d45349eb47e5e1ef90 | Extended mixed-mode change prefix | 2     | +53   | -0      |
| c46ae0aad3158884a1a049db016bfc200d2d33e6 | Transaction ID digest bounds      | 1     | +1    | -1      |
| 039e2f9644876443ad1c5ad78082cee0e8901cba | Shared emulator test transport    | 1     | +0    | -6      |

### Input history across outputs 29e14b4a417875495bbb5d029e844294f05125c9

Previously, saving a payment output reset or finalized the current input digest, so later outputs could compare against the wrong input history. The signer now resets at the request boundary; the digest finalizes a SHA256 context snapshot and an accepted output saves the comparison key without resetting the hash. The multi-output and OP\_RETURN native regression runs in both variants.

| File                                  | Added | Deleted |
|---------------------------------------|-------|---------|
| include/keepkey/firmware/txin_check.h | +2    | -7      |
| lib/firmware/signing.c                | +2    | -4      |
| lib/firmware/transaction.c            | +3    | -13     |
| lib/firmware/txin_check.c             | +6    | -9      |
| unittests/firmware/CMakeLists.txt     | +2    | -0      |
| unittests/firmware/transaction.cpp    | +41   | -2      |

### Accepted history after refusal b57eb71c2ee1babfeb20805b7f6b64ad70c4e925

A refused duplicate output could replace the previously accepted comparison key, letting a retry lose the warning. The save now happens only after refusal checks pass. The transaction regression retries changed inputs three times and then accepts the original input set; both variants execute it.

| File                               | Added | Deleted |
|------------------------------------|-------|---------|
| lib/firmware/transaction.c         | +2    | -2      |
| unittests/firmware/transaction.cpp | +17   | -0      |

### Extended mixed-mode change prefix a1e7f53155ee3db53991f9d45349eb47e5e1ef90

Mixed script purposes under an extended wallet path could be treated as change even when a leading wallet branch differed. The helper now compares all components before the final five wallet components. The test checks depths five through eight, altered leading components, and a second mismatched input in both variants.

| File                           | Added | Deleted |
|--------------------------------|-------|---------|
| lib/firmware/signing.c         | +5    | -0      |
| unittests/firmware/signing.cpp | +48   | -0      |

### Transaction ID digest bounds c46ae0aad3158884a1a049db016bfc200d2d33e6

The input-history hash used a type-size expression that could differ from the transaction-ID byte array. It now hashes the actual `prev_hash.bytes` length`. Current-source review verified the phase-one call; full and Bitcoin-only native suites passed.

| File                   | Added | Deleted |
|------------------------|-------|---------|
| lib/firmware/signing.c | +1    | -1      |

### Shared emulator test transport 039e2f9644876443ad1c5ad78082cee0e8901cba

The Bitcoin-only USB regression carried duplicate transport setup. Removing that branch lets the common test setup initialize both variants. The named tiny-acknowledgement regression executed and passed in both candidate images.

| File                          | Added | Deleted |
|-------------------------------|-------|---------|
| unittests/firmware/usb_rx.cpp | +0    | -6      |

## Later signing interactions

| Commit    | Change                      | Files | Added | Deleted |
|-----------|-----------------------------|-------|-------|---------|
| 533b38eb1 | Multisig input quorum       | 2     | +69   | -0      |
| 49930bc8a | Sighash suffix bounds       | 1     | +22   | -4      |
| 0a7e0cf4a | Validated workflow progress | 19    | +335  | -71     |
| 64e5d2cb2 | Final release audit guard   | 12    | +135  | -41     |

### Multisig input quorum 533b38eb1

Adds an input-side quorum guard before fee accounting. It shares signing validation but does not alter the P04 input digest or change-path checks.

| File                           | Added | Deleted |
|--------------------------------|-------|---------|
| lib/firmware/signing.c         | +21   | -0      |
| unittests/firmware/signing.cpp | +48   | -0      |

### Sighash suffix bounds 49930bc8a

Bounds multisig and single-signature suffix writes. The change shares signing output paths; both candidate native variants pass.

| File                   | Added | Deleted |
|------------------------|-------|---------|
| lib/firmware/signing.c | +22   | -4      |

## Validated workflow progress 0a7e0cf4a

Renews auto-lock only on accepted workflow progress. The signer's request-boundary digest reset remains in current source.

| File                                                   | Added | Deleted |
|--------------------------------------------------------|-------|---------|
| docs/release/audit-units/autolock-workflow-progress.md | +21   | -0      |
| include/keepkey/board/usb.h                            | +5    | -0      |
| include/keepkey/firmware/home_sm.h                     | +2    | -1      |
| lib/board/usb.c                                        | +6    | -0      |
| lib/firmware/ethereum.c                                | +2    | -0      |
| lib/firmware/fsm.c                                     | +0    | -11     |
| lib/firmware/fsm_msg_binance.h                         | +1    | -0      |
| lib/firmware/fsm_msg_cosmos.h                          | +1    | -0      |
| lib/firmware/fsm_msg_eos.h                             | +5    | -0      |
| lib/firmware/fsm_msg_mayachain.h                       | +1    | -0      |
| lib/firmware/fsm_msg_osmosis.h                         | +1    | -0      |
| lib/firmware/fsm_msg_tendermint.h                      | +1    | -0      |
| lib/firmware/fsm_msg_thorchain.h                       | +1    | -0      |
| lib/firmware/fsm_msg_zcash.h                           | +3    | -0      |
| lib/firmware/home_sm.c                                 | +10   | -15     |
| lib/firmware/recovery_cipher.c                         | +3    | -1      |
| lib/firmware/reset.c                                   | +2    | -0      |
| lib/firmware/signing.c                                 | +20   | -13     |
| unittests/firmware/fsm.cpp                             | +250  | -30     |

## Final release audit guard 64e5d2cb2

Exposes production input validation for an emulator regression and adds a quorum test. It does not remove P04 history or path checks.

| File                                  | Added | Deleted |
|---------------------------------------|-------|---------|
| .github/workflows/ci.yml              | +5    | -5      |
| docs/dice-vs-coldcard.md              | +1    | -1      |
| include/keepkey/board/keepkey_board.h | +2    | -1      |
| include/keepkey/board/usb.h           | +0    | -5      |
| include/keepkey/firmware/signing.h    | +5    | -0      |
| lib/emulator/libkemu.c                | +6    | -0      |
| lib/firmware/fsm.c                    | +6    | -9      |
| lib/firmware/signing.c                | +6    | -0      |
| lib/firmware/storage.c                | +13   | -4      |

| File                             | Added | Deleted |
|----------------------------------|-------|---------|
| unittests/firmware/fsm.cpp       | +18   | -1      |
| unittests/firmware/signing.cpp   | +24   | -9      |
| unittests/firmware/thorchain.cpp | +49   | -6      |

## Current-source reconciliation and findings

txin\_check.c finalizes a hash-context copy; signing\_init and signing\_abort reset current history; transaction.c skips saving a comparison key for OP\_RETURN and refused payments. The mixed-mode helper requires a minimum depth of five, equal path lengths and matching leading components. Phase-one input hashing uses the exact transaction-ID byte array. The later multisig and suffix guards are present in the same candidate signer. **Disposition:** no newly identified in-scope defect. No historical unit was inferred accepted solely from ancestry.

## Executed evidence and limits

Full and Bitcoin-only owned images, respectively

sha256:18f7375986270c6bdcea6155e9fe8382d5a4faca8f0466ff3bf727b759a2e9f3 and

sha256:12d356b3912a0e7f76923db50368ee66e979fed3935174b6084726090a8f99db, were built from code/tests/pins identical to this docs-only review branch. make xunit executed and passed the named

Signing.MixedModeChangeMustPreserveLeadingPathComponent,

Transaction.ChangedInputsTriggerDuplicateOutputRefusal,

Transaction.IdenticalOutputsWithinOneTransactionKeepInputHistory and

USBX.TinyAcknowledgementDoesNotReusePreviousSecret cases in both variants. Full totals: 573 firmware, 17 board, 18 crypto, 6 Pallas. Bitcoin-only totals: 131 firmware, 17 board, 18 crypto. Log SHA256: full

5a452156d0b2264f480ac5d640e388e1ea9ab10bf57783751bcde2f947459d; Bitcoin-only

4509a2ef1d05d5cdfa21401a6350fd562a48b1b6e69be3dcb14f211ee25ff49e. Complete local logs: /private/tmp/kk-fw-715-p03-owned-evidence.

[Earlier CI run 34951131013](#) at 7e091af157131897adc5514de392570c32088946 has full/Bitcoin-only native artifacts 10388679573/10389512420, host artifacts 10390030970/10389023825, and ARM firmware artifacts 10389287571/10388589162. Both host JUnit files pass Bitcoin test\_one\_one\_fee; Bitcoin-only also passes test\_bitcoin\_signing\_survives\_the\_strip, expectedly skipped in the full host variant. The selected native cases ran in both native artifacts. From that run to the source candidate only CI workflows changed. From the owned image source to this report branch only audit documentation/SOP changed. These are firmware-equivalent results, not exact-head workflow certification.

**Remaining release gates:** physical signing/OLED review, signed-device upgrade, and final exact-workflow CI acceptance remain outside this local unit. Report rendering and the final review checkpoint are recorded in the PR after this report is frozen.